

# Plan of Action & Milestones (POA&M) — 2026-07

---

Remediation register for the security findings recorded in [security-assessment-2026-07.md](#). IDs match that document one-for-one; read the assessment for each finding's evidence, failure scenario, and full recommendation — this table is the tracking view, not a restatement.

**Date:** 2026-07 (assessment date 2026-07-28).

**What this covers.** Every security or technical finding from the 2026-07 assessment: 15 medium, 42 low, 12 informational. All are **Open** — the 2026-07 pass was documentation-only, so no code, template, or script change was made in response to any finding, and nothing has been remediated since the prior (2026-07-27) assessment either. The five mediums carried forward from that assessment (SA-2026-07-09, -10, -11, -14, -15) are included here with their status unchanged.

**What this does not cover.**

- **Accepted risks and posture decisions are not POA&M items.** The sixteen deliberate, SSP-scoped decisions (Object Lock deferral, the loopback telemetry resolution, fail-closed spend enforcement, account-wide Bedrock prompt logging, SSE-S3 on the ALB log bucket, and the rest) are enumerated in §2 of the assessment. They are decisions to be stated in the SSP, not defects to be closed.
- **Documentation-package gaps** — completeness and accuracy gaps in the ATO document set itself — are tracked in [ato-package-gaps.md](#) and are deliberately not duplicated as rows here. The one overlap is SA-2026-07-01, which is filed as a security finding because a private key's lifecycle, not only its description, is at issue.

**Owner column.** `org` = the operating organization must act outside this repository (a landing-zone or account-level prerequisite); `operator` = a per-deployment configuration or procedural change; `TBD` = code, template, or script work in this repository, not yet assigned. This is a reusable template, so the concrete owner is assigned by the deploying organization.

**Ordering.** Rows are ordered by severity (Medium → Low → Informational), then by ID.

---

**Register**

| ID            | Severity | Description                                                                                                                                                                                                                                  | Recommendation                                                                                                                                                                                                                                  | Owner    | Status |
|---------------|----------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|--------|
| SA-2026-07-01 | Medium   | ALB→task TLS keys are generated on the build host and baked into the images — shared per image, rotated only by rebuild (the package's former per-task-generation claim was corrected with the assessment; residual technical component Low) | Decide the key-lifecycle posture: accept build-time generation in the SSP (ECR pull implies key access), or move generation to the container entrypoint for a per-task key                                                                      | TBD      | Open   |
| SA-2026-07-02 | Medium   | Six roles hold <code>kms:Decrypt/GenerateDataKey</code> on the shared CMK with no <code>kms:ViaService</code> scoping                                                                                                                        | Add <code>kms:ViaService</code> conditions ( <code>secretsmanager</code> for exec/Lambda roles; <code>s3 + kms:EncryptionContext:aws:s3:arn</code> for the portal task and Firehose roles)                                                      | TBD      | Open   |
| SA-2026-07-03 | Medium   | Build scripts can silently create permanently non-CMK ECR repositories when <code>KMS_KEY_ARN</code> is unset                                                                                                                                | Move the fail-closed check into <code>ensure_ecr_repo</code> with a named override; warn loudly on an existing non-KMS repository                                                                                                               | TBD      | Open   |
| SA-2026-07-04 | Medium   | The activity-archive S3 bucket has no bucket policy and no versioning, unlike every sibling audit bucket                                                                                                                                     | Add <code>DenyInsecureTransport</code> (and an SSE-enforcement deny), enable versioning, add a <code>cfn-guard</code> rule for transport denies                                                                                                 | TBD      | Open   |
| SA-2026-07-05 | Medium   | Nothing in the template or CI rejects <code>0.0.0.0/0</code> for <code>ClientIngressCidr</code> ; the default is <code>10.0.0.0/8</code>                                                                                                     | Tighten the <code>AllowedPattern</code> or add a <code>Rules</code> assertion; add a <code>cfn-guard</code> rule against <code>0.0.0.0/0</code> ingress; set the deployment's CIDR to the ZPA App Connector range                               | operator | Open   |
| SA-2026-07-06 | Medium   | Portal <code>SESSION_SECRET</code> and <code>OIDC_CLIENT_SECRET</code> default to <code>""</code> instead of failing closed at boot                                                                                                          | Use <code>env[...]</code> with a ≥32-character length assertion for both; add a boot-failure test                                                                                                                                               | TBD      | Open   |
| SA-2026-07-07 | Medium   | The device-flow gateway token is never bound to the portal session identity, so an approved token from another admin is accepted                                                                                                             | Compare the token <code>sub</code> to the session <code>sub</code> in <code>_poll_device_flow</code> and both refresh paths; refuse, clear, and audit on mismatch; fix the test that asserts the weaker behavior                                | TBD      | Open   |
| SA-2026-07-08 | Medium   | Vendored Python wheels are installed without <code>--require-hashes</code> ; transitive versions are pinned only by which file sits in <code>vendor/</code>                                                                                  | Emit a committed <code>requirements.lock</code> with full transitive <code>--hash=sha256: pins</code> ; install <code>--require-hashes --no-deps</code>                                                                                         | TBD      | Open   |
| SA-2026-07-09 | Medium   | <code>mirror-collector.sh</code> lacks <code>--platform linux/amd64</code> and an architecture assertion, and pushes a fixed tag into an IMMUTABLE repository (prior SUP-1)                                                                  | Back-port the platform pin plus post-pull assertion; adopt the content-derived <code>&lt;tag&gt;-&lt;12-hex digest&gt;</code> scheme                                                                                                            | TBD      | Open   |
| SA-2026-07-10 | Medium   | The collector self-metrics heartbeat keeps AMP ingestion non-zero, blinding the only metrics-pipeline alarm to total client-metric loss (prior AUD-2)                                                                                        | Add an alarm specific to client data (AMP rule on <code>absent_over_time(claude_code_cost_usage[...])</code> or on <code>increase(failed_translations)</code> ); otherwise document the operator diagnostic cadence as the compensating control | TBD      | Open   |
| SA-2026-07-11 | Medium   | Firehose delivery errors are recorded nowhere and the durable activity-archive leg is unmonitored (prior AUD-3)                                                                                                                              | Enable <code>CloudWatchLoggingOptions</code> into a CMK log group; alarm on <code>DeliveryToS3.Success &lt; 1</code> and <code>DataFreshness</code>                                                                                             | TBD      | Open   |
| SA-2026-07-12 | Medium   |                                                                                                                                                                                                                                              |                                                                                                                                                                                                                                                 | TBD      | Open   |

| ID            | Severity | Description                                                                                                                                                                    | Recommendation                                                                                                                                                                                       | Owner | Status |
|---------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|--------|
|               |          | No alarm on ALB 5xx, target health, or ECS running-task count — the primary symptom of both fail-closed postures (prior AUD-5)                                                 | Add <code>UnHealthyHostCount</code> , <code>HTTPCode_Target_5XX_Count</code> , and <code>RunningTaskCount &lt; DesiredCount</code> alarms wired to <code>AlarmSnsTopicArn</code>                     |       |        |
| SA-2026-07-13 | Medium   | CloudTrail is an unstated, unverified assumption; S3 data events on the activity-archive and prompt-log buckets are not requested anywhere                                     | Add trail + S3 data events + KMS key-usage events to the org-prerequisite list and the ConOps control inventory; state which AU-2/AU-6 coverage is inherited; verify at deploy                       | org   | Open   |
| SA-2026-07-14 | Medium   | Stack 01 defines zero alarms, so the fail-closed spend-store dependency is unmonitored (prior AUD-1)                                                                           | Add RDS alarms (free storage, connections, CPU) plus an event subscription to 01, wired to an <code>AlarmSnsTopicArn</code> parameter 01 does not yet have; correct <code>cost-controls.md</code> §5 | TBD   | Open   |
| SA-2026-07-15 | Medium   | Portal audit writes fail open and are swallowed; stack 04 has no alarm surface at all (prior AUD-4)                                                                            | Add an <code>AlarmSnsTopicArn</code> parameter to 04 and pass it from the deploy script; emit and alarm on an audit-write-failure metric; escalate the swallowed <code>_ensure_stream</code> failure | TBD   | Open   |
| SA-2026-07-16 | Low      | The CloudFormation deploy-artifacts bucket is created outside the templates with SSE-S3, no TLS-only policy, and no versioning                                                 | Use SSE-KMS when <code>KMS_KEY_ARN</code> is set; add <code>DenyInsecureTransport</code> and versioning; add it to the encryption inventory                                                          | TBD   | Open   |
| SA-2026-07-17 | Low      | All three ECS execution roles attach <code>AmazonECSTaskExecutionRolePolicy</code> , granting <code>logs:PutLogEvents</code> on <code>Resource: "*"</code>                     | Replace with an inline policy scoping ECR to <code>&lt;prefix&gt;-*</code> and <code>logs:</code> to each stack's own log groups                                                                     | TBD   | Open   |
| SA-2026-07-18 | Low      | <code>ActivityFirehoseRole</code> 's trust policy lacks <code>aws:SourceAccount / SourceArn</code> , unlike both siblings                                                      | Add both conditions to match the siblings                                                                                                                                                            | TBD   | Open   |
| SA-2026-07-19 | Low      | The activity Firehose delivery stream has no SSE, so buffered per-user content sits under an AWS-owned key                                                                     | Set <code>CUSTOMER_MANAGED_CMK</code> against the stack CMK (verify the subscription principal's KMS needs live first), or record the leg as AWS-owned-key in the inventory                          | TBD   | Open   |
| SA-2026-07-20 | Low      | The rotation Lambda accepts an arbitrary <code>SecretId</code> from the event and the invoke permission is account-scoped, not secret-scoped                                   | Assert <code>event["SecretId"] == APP_SECRET_ARN</code> , check <code>RotationEnabled</code> , add <code>SourceArn</code> to the permission, add tests                                               | TBD   | Open   |
| SA-2026-07-21 | Low      | The telemetry task-role write grant to the activity log group is not gated on <code>ForwardActivityLogs</code>                                                                 | Gate on <code>HaveTelemetry</code> AND <code>ForwardActivityLogs</code> ; drop the unused <code>DescribeLogStreams</code>                                                                            | TBD   | Open   |
| SA-2026-07-22 | Low      | Two VPC-endpoint policies are wider than needed ( <code>logs:PutRetentionPolicy</code> on <code>*</code> ; <code>s3:*</code> ; an unconditioned CFN-response-bucket statement) | Drop <code>logs:PutRetentionPolicy</code> ; enumerate the S3 actions actually used; add an account guard to the CFN-response statement                                                               | TBD   | Open   |
| SA-2026-07-23 | Low      | The Secrets Manager endpoint policy's <code>secret:rds!*</code> matches every RDS-managed secret in the account (prior IAM-2)                                                  | Import 01's <code>DBMasterSecretArn</code> and scope to it                                                                                                                                           | TBD   | Open   |

| ID            | Severity | Description                                                                                                                                                                   | Recommendation                                                                                                                                                         | Owner    | Status |
|---------------|----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|--------|
| SA-2026-07-24 | Low      | The ECR Lambda-pull repository policy scopes by account only, with no <code>aws:SourceArn</code> (prior IAM-3)                                                                | Add <code>aws:SourceArn</code> for the specific function                                                                                                               | TBD      | Open   |
| SA-2026-07-25 | Low      | One shared endpoint SG gives Grafana, the portal, the Lambda, and the admin host network reach to the bedrock-runtime endpoint                                                | Give <code>BedrockRuntimeEndpoint</code> a dedicated SG admitting only the gateway service SG; update <code>network-access-controls.md</code>                          | TBD      | Open   |
| SA-2026-07-26 | Low      | The optional proxy port is opened to <code>0.0.0.0/0</code> egress from three SGs                                                                                             | Add an optional <code>ProxyCidr</code> parameter to scope proxy-port egress                                                                                            | TBD      | Open   |
| SA-2026-07-27 | Low      | <code>TlsSecurityPolicy</code> is unconstrained free text with no CI gate enforcing a FIPS/TLS 1.2 floor                                                                      | Add <code>AllowedValues</code> ; add a guard rule on <code>SslPolicy</code> and listener <code>Protocol</code>                                                         | TBD      | Open   |
| SA-2026-07-28 | Low      | The ADOT sidecar pins every listener to loopback except <code>service.telemetry.metrics.address</code> , which inherits the build default                                     | Set <code>service.telemetry.metrics.address: 127.0.0.1:8888</code> explicitly                                                                                          | TBD      | Open   |
| SA-2026-07-29 | Low      | No CI gate asserts security-group source/CIDR breadth (prior NET-1)                                                                                                           | Add cfn-guard rules for <code>0.0.0.0/0</code> ingress and minimum prefix length                                                                                       | TBD      | Open   |
| SA-2026-07-30 | Low      | <code>trusted_proxies</code> spans the whole VPC CIDR and the gateway's X-Forwarded-For parsing order is unconfirmed against the binary                                       | Test a spoofed XFF header live; narrow <code>trusted_proxies</code> to the ALB subnets; otherwise state the recorded client IP as untrusted in the SSP and to the SIEM | operator | Open   |
| SA-2026-07-31 | Low      | Portal cookies use <code>Path=/portal</code> with no <code>__Host-</code> prefix, leaving the documented sibling-domain cookie-tossing path open                              | Move cookies to <code>Path=/' with <code>__Host-</code>; clear <code>portal_txn</code> on callback failure branches</code>                                             | TBD      | Open   |
| SA-2026-07-32 | Low      | <code>/portal/me</code> trusts the gateway to scope its response and applies no post-filter                                                                                   | Filter to items whose scope/actor user id equals the session <code>sub</code> ; error explicitly on foreign rows; add a test                                           | TBD      | Open   |
| SA-2026-07-33 | Low      | The release-manifest checksum is spliced unvalidated into the generated <code>install.cmd/install.sh</code> ; <code>RELEASE_VERSION</code> has no <code>AllowedPattern</code> | Reject anything not <code>^[0-9a-fA-F]{64}\$</code> ; add an <code>AllowedPattern</code> to <code>RELEASE_VERSION</code>                                               | TBD      | Open   |
| SA-2026-07-34 | Low      | The db-admin Lambda inlines secret-derived usernames into SQL as the RDS master with no allowlist check                                                                       | Assert <code>username</code> in <code>APP_USERS</code> before interpolation; add tests                                                                                 | TBD      | Open   |
| SA-2026-07-35 | Low      | <code>set-spend-limit.sh</code> builds request JSON by string interpolation and never validates <code>--id</code>                                                             | Validate <code>--id</code> , or build the body with <code>jq -n --arg</code>                                                                                           | TBD      | Open   |
| SA-2026-07-36 | Low      | The portal has no logout route, no session revocation, and sends no HSTS header                                                                                               | Add a CSRF-protected <code>POST /portal/logout</code> ; add HSTS; consider a shorter session TTL                                                                       | TBD      | Open   |
| SA-2026-07-37 | Low      | No step-up confirmation for org-wide spend-cap writes within a connected session (prior AUTH-2)                                                                               | Require an explicit typed confirmation for org-scope writes                                                                                                            | TBD      | Open   |

| ID            | Severity | Description                                                                                                                                                     | Recommendation                                                                                                                                                                                                                       | Owner | Status |
|---------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------|--------|
| SA-2026-07-38 | Low      | Failed CSRF checks on admin endpoints are not audited, although group denials are (prior AUTH-3)                                                                | Audit CSRF failures on the same path as group denials                                                                                                                                                                                | TBD   | Open   |
| SA-2026-07-39 | Low      | Grafana group parameters lack the <code>AllowedPattern</code> their gateway equivalents carry and splice into a <code>JMESPath</code> expression (prior AUTH-4) | Add matching <code>AllowedPattern</code> constraints                                                                                                                                                                                 | TBD   | Open   |
| SA-2026-07-40 | Low      | The oversized-cookie guard built for <code>portal_gw</code> was never applied to <code>portal_session</code> (prior AUTH-5)                                     | Apply the same guard, with an explicit error instead of a login loop                                                                                                                                                                 | TBD   | Open   |
| SA-2026-07-41 | Low      | <code>OAuth code</code> and <code>state</code> are logged verbatim on token-exchange failure (prior APP-1)                                                      | Redact the query string in the error path                                                                                                                                                                                            | TBD   | Open   |
| SA-2026-07-42 | Low      | Authenticated pages, including admin and audit views, are sent without <code>Cache-Control: no-store</code> (prior APP-3)                                       | Add <code>Cache-Control: no-store</code> to authenticated responses                                                                                                                                                                  | TBD   | Open   |
| SA-2026-07-43 | Low      | No socket read timeout; slow clients can hold worker threads (prior APP-5)                                                                                      | Set a read timeout in the gunicorn configuration                                                                                                                                                                                     | TBD   | Open   |
| SA-2026-07-44 | Low      | The admin's gateway bearer and refresh tokens ride a signed-but-unencrypted cookie (prior KEY-1)                                                                | Encrypt the cookie payload or move to a server-side session handle                                                                                                                                                                   | TBD   | Open   |
| SA-2026-07-45 | Low      | Artifact re-verification compares a binary against metadata that travels with it on the same share                                                              | Re-run <code>gpg --verify</code> in <code>publish-portal-release.sh</code> when the key and <code>.sig</code> are present; prefer <code>manifest.json</code> over <code>CHECKSUMS.txt</code> in <code>build-and-push-image.sh</code> | TBD   | Open   |
| SA-2026-07-46 | Low      | Two of three TLS-key generators omit the <code>rm -f -before-umask</code> the repository's own rule mandates (prior KEY-2)                                      | Add <code>rm -f</code> for key and certificate inside both subshells                                                                                                                                                                 | TBD   | Open   |
| SA-2026-07-47 | Low      | The Windows installer skips SHA-256 verification silently when <code>-Sha256</code> is absent                                                                   | Warn (mirroring the Linux script) or fail unless a named opt-out switch is passed                                                                                                                                                    | TBD   | Open   |
| SA-2026-07-48 | Low      | The Authenticode check is a CN-substring match and the portal never pins a signer thumbprint                                                                    | Add an optional <code>PortalSignerThumbprint</code> parameter that <code>build_install_cmd</code> bakes into the generated installer                                                                                                 | TBD   | Open   |
| SA-2026-07-49 | Low      | The Linux client's only integrity control is a checksum from a manifest in the same bucket as the binary                                                        | Publish a GPG-verified <code>manifest.sig</code> compared against a value not sourced from the same mutable prefix, or record as an accepted risk bounded by bucket-write control                                                    | TBD   | Open   |
| SA-2026-07-50 | Low      | <code>mirror-python-deps.sh</code> does not pin the download platform, contradicting its own universal-wheels contract                                          | Add <code>--platform manylinux2014_x86_64 --implementation cp --abi cp312</code> ; restate the contract                                                                                                                              | TBD   | Open   |
| SA-2026-07-51 | Low      | None of the four image builds pins <code>--platform linux/amd64</code> or asserts architecture before pushing to an IMMUTABLE repository                        | Add the platform flag plus a pre-push <code>docker inspect</code> assertion to all four                                                                                                                                              | TBD   | Open   |
| SA-2026-07-52 | Low      |                                                                                                                                                                 |                                                                                                                                                                                                                                      | TBD   | Open   |

| ID            | Severity | Description                                                                                                                                                                    | Recommendation                                                                                                                         | Owner    | Status |
|---------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------|----------|--------|
|               |          | The mirrored base-image override is unenforced; builds silently fall back to floating upstream tags where egress exists (prior SUP-2)                                          | Warn, or fail behind a named override, when the resolved base-image reference lacks an <code>@sha256:</code> digest                    |          |        |
| SA-2026-07-53 | Low      | The CI <code>cf-n-guard</code> installer is piped from a floating <code>main</code> branch into <code>sh</code> , unverified; <code>cf-n-lint</code> is unpinned (prior SUP-3) | Pin the installer to a released tag and verify its checksum; pin <code>cf-n-lint</code>                                                | TBD      | Open   |
| SA-2026-07-54 | Low      | CI test dependencies use open-ended <code>&gt;=</code> constraints with no lockfile or hashes (prior SUP-4)                                                                    | Add a hashed lockfile for the CI toolchain                                                                                             | TBD      | Open   |
| SA-2026-07-55 | Low      | The certificate-expiry alarm can silently stop monitoring, and neither <code>stack-02</code> alarm signals recovery                                                            | Add <code>InsufficientDataActions</code> to the certificate alarm; add <code>OKActions</code> to both, matching <code>stack 03</code>  | TBD      | Open   |
| SA-2026-07-56 | Low      | Five log-retention parameters accept values CloudWatch Logs rejects, failing a deploy mid-update on audit-bearing stacks                                                       | Add <code>AllowedValues</code> matching the CloudWatch Logs retention set to all five                                                  | TBD      | Open   |
| SA-2026-07-57 | Low      | Bedrock prompt-log delivery (opt-in) has no delivery monitoring on either the CloudWatch or the S3 leg                                                                         | Add an <code>IncomingLogEvents</code> alarm on the prompt log group when the feature is on; document the manual S3-leg check           | TBD      | Open   |
| SA-2026-07-58 | Info     | The Bedrock prompt-logs bucket grant is bucket-wide <code>s3:PutObject</code> because the delivery data prefix is undocumented — the one carried-forward open TODO in the code | Capture the real prefix from the first live delivery, then scope the grant; the in-template TODO comment tracks it                     | TBD      | Open   |
| SA-2026-07-59 | Info     | A single CMK covers every data class, with key separation entirely IAM-side                                                                                                    | State the shared-key blast radius as an accepted risk in the SSP, or split a second CMK for the prompt-log and activity-archive stores | operator | Open   |
| SA-2026-07-60 | Info     | <code>rules.guard</code> has no S3-encryption rule, so a future bucket without SSE-KMS passes CI                                                                               | Add the rule with a named <code>AlbLogsBucket</code> exception                                                                         | TBD      | Open   |
| SA-2026-07-61 | Info     | The Grafana break-glass admin password is injected even when the login form is disabled                                                                                        | Gate the injection on <code>GrafanaDisableLoginForm</code>                                                                             | TBD      | Open   |
| SA-2026-07-62 | Info     | Three unauthenticated health endpoints are reachable within <code>ClientIngressCidr</code> , and no WAF fronts the ALB                                                         | State both in the SSP as decisions (health checks are required; the ALB is internal-only)                                              | operator | Open   |
| SA-2026-07-63 | Info     | The ALB access-log bucket policy lacks the <code>DenyInsecureTransport</code> its siblings carry (SSE-S3 on that bucket is the correct documented exception, not a finding)    | Add the transport deny for consistency                                                                                                 | TBD      | Open   |
| SA-2026-07-64 | Info     | The portal CSP has no <code>base-uri</code> directive                                                                                                                          | Add <code>base-uri 'none'</code>                                                                                                       | TBD      | Open   |

| ID            | Severity | Description                                                                                                                                                        | Recommendation                                                                                   | Owner    | Status |
|---------------|----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------|----------|--------|
| SA-2026-07-65 | Info     | OAuth authorization codes land in ALB access logs via the callback query string                                                                                    | Record one SSP line; bounded by one-time use, S256 PKCE, and confidential-client authentication  | operator | Open   |
| SA-2026-07-66 | Info     | <code>admin_pending.html</code> renders the device-flow <code>verify_url</code> as an <code>href</code> with no scheme allowlist                                   | Allowlist <code>https:</code> before rendering                                                   | TBD      | Open   |
| SA-2026-07-67 | Info     | Audit-write amplification and no rate limiting: denial writes on every non-admin admin GET, unthrottled 100+ MB download streams                                   | Consider a per-principal rate limit on <code>/portal/download</code> and denial-write coalescing | TBD      | Open   |
| SA-2026-07-68 | Info     | Operator-configured team and cost-center values are not screened for <code>"</code> before being spliced into the generated <code>install.cmd</code> (prior APP-4) | Add <code>"</code> to the boot-time character rejection set                                      | TBD      | Open   |
| SA-2026-07-69 | Info     | Pester is installed unpinned in CI ( <code>-SkipPublisherCheck</code> is inert on Linux runners) (prior SUP-5)                                                     | Pin the Pester version                                                                           | TBD      | Open   |

## Suggested remediation sequence

Carried forward from the prior assessment and re-ordered for the current finding set. Nothing here blocks operation of the pilot; the sequence is a suggestion for batching related work, not a schedule.

1. **Alarm coverage** — SA-2026-07-11, -12, -14, -15, -55, -57 across stacks 01/03/04, wired to the existing `AlarmSnsTopicArn` (and adding that parameter to 01 and 04). This is the single largest cluster and the one with the clearest AU-5/SI-4 mapping.
2. **Supply-chain pinning that can break a deploy** — SA-2026-07-09 (arch pin), -51 (build arch pin), -03 (fail-closed CMK on ECR creation), -50 (wheel platform pin).
3. **Telemetry-blindness decision** — SA-2026-07-10: build the AMP alerting path, or formally adopt the operator-diagnostic cadence as the compensating control and say so in the SSP.
4. **Organization prerequisites** — SA-2026-07-13 (CloudTrail plus S3 data events) and the per-deployment CIDR in SA-2026-07-05. These need no repository change and can proceed in parallel.
5. **Portal authentication and session hardening** — SA-2026-07-06, -07, -31, -32, -36, -37, -38, -40, -41, -42, -43, -44.
6. **IAM and bucket-policy scoping** — SA-2026-07-02, -04, -17, -18, -20, -21, -22, -23, -24, -25.
7. **TLS key-lifecycle decision** — SA-2026-07-01: the documentation now matches the code (build-time, image-baked keys); what remains is the deliberate SSP decision on whether that posture stands or per-task generation is introduced.
8. **Remaining low and informational items** as capacity allows.